复旦大学计算机学院

2022~2023 学年第 1 学期期末考试试卷

√A 卷 □B 卷 □ C 卷

课程名称： 信息系统安全 **课程代码：** _____

开课院系： 计算机 **考试形式：** 开卷/闭卷/课程论文/其他

姓名： _____ **学号：** _____ **专业：** _____

提示：请同学们秉持诚实守信宗旨，谨守考试纪律，摒弃考试作弊。学生如有违反学校考试纪律的行为，学校将按《复旦大学学生纪律处分条例》规定予以严肃处理。

（装订线内不要答题）

题号	1	2	3	4	5	6	7	8	总分
得分									

（以下为试卷正文**或课程论文题目**）

重要提示：在未包含特别说明时，试卷涉及的攻击环境为 32 位 x86 构架上的 Linux。

一、选择题 （3 分*5）

1) 在堆溢出造成的任意写攻击中, 攻击者将 free-list 的某个 node 的链表头覆盖完成后, 在下列什么时机任意写才可能会被触发?

A）malloc() 1K 的内存 B）free 4M 的内存 C）malloc() 4M 的内存 D）read()系统调用

2）用 C++ shared_ptr 作为链表 next 指针不可以解决的问题有：

A）栈溢出 B）内存泄漏

C）Use after Free D) Double Free

3）以下措施不可以缓解 Buffer Overflow 攻击的有：

A）Stack Canary

B）页表 NX bit

C）编译器自动边界检查

D）Address Sanitizer

4）GCC 编译的程序存放 GOT 表的内存页应具有哪些权限

A）读写　　B）读+执行　　C）读写+执行　　D）只读

5）下列可以缓解 TCP Sync Flooding 的手段为：

A）用时间做序列号　　B) Sync Cookie

C）TCP 协议栈内存限制　　D）增大系统内存

二、简答题（6 分*6，每题作答不超过 100 字）

1）请结合理解，分别简述动态程序分析与静态程序分析的优劣势。

2）某同学将一个指针变量从子类指针类型转换成为父类指针类型后，发现变量的值发生了改变，请问为什么。

3）如下实现的多线程程序有什么问题?

Thread 1	Thread 2
data = prepare_data(); ready = true;	while(!ready){} tmp = data;

4）简述 Google NaCl 如何保证跳转指令不会跳转到指令中间的立即数。

5）请简述可变参数函数如何获取参数?

6）某厂生产的嵌入式设备生成的第一个随机数只有 20 种不同的可能，如果 TCP 协议栈使用了第一个随机数作为随机数种子生成后续协议栈用到的所有随机数，这种嵌入式设备的 TCP 协议会受到怎样的影响?

三、应用题 （11’+14’+9’+9’+6’）

1、假设给定的代码从 caller()运行至 callee()函数内时，栈顶附近内存如下表所示。
请分析内存并回问：
1）变量 addr 的值是多少，请写出推理过程？5'
1）此时的 EBP 寄存器存储的值是多少？callee()执行完成后会返回到哪个地址？3'+3'

```
void caller(){
    void* addr = malloc(512);
    callee(addr);
}

void callee(void* addr){
    .....
}
```

Lower address ---------> Higher Address																						
02	04	06	34	12	ff	bf	34	12	58	08	0c	02	04	62	0c	02	04	62	64	12	ff	bf	45

2、图中栈内存结构为 vulp 函数调用 scanf 时，进入 scanf 后捕获的。请分析如下代码以及内存结构并作答。未标明大小时，每格内存占 4byte。

```
Void vulp(){
    char s[240];
    scanf("%s",s);
    printf(s);
}
```

<table>
<tr><td rowspan="10">Higher Address

Lower Address</td><td></td><td rowspan="2">Caller of vulp’ stack frame</td></tr>
<tr><td>⑤</td></tr>
<tr><td>④</td><td rowspan="6">vulp 的 stack frame</td></tr>
<tr><td>字符串 s
(256 Byte)</td></tr>
<tr><td>①</td></tr>
<tr><td>②</td></tr>
<tr><td>③</td></tr>
<tr><td>⑥</td><td rowspan="2">scanf 的 stack frame</td></tr>
<tr><td>…</td></tr>
</table>

1）请简述①-⑥这几块内存分别存储了什么。3'

2）若⑥的值为 0xbe12bf54，①的值为多少？ 4'

3）若③的值为 0xbe12bf54，请问输入什么可以让程序运行至 0x56 继续执行。7'

3、攻击者发动 spectra 或者 meltdown 攻击时，其利用访问 a 数组各个元素的的时间来确定某个个 secret byte 的值为多少。已知目标平台 CPU 的一个 cache line 大小为 64 byte。请问：

1）如果目标平台 CPU 没有 prefetch，a 数组长度（代码中的①）最小应该为多大？3’此时代码中②应该填多少？2’
2)如果目标平台 CPU 访问一个 cache line 时会向后 prefetch 2-4 个 cache line，则最小的①为多少？2’此时②应该填多少？2’

```
int a[①];
…
a[access(secret)*②+64] = 100;
```

4、请填写在对如下程序进行 Live Variable 分析的时候，各行代码运行前后时刻的 Live Variable Set(简写为 VS)是什么。3’根据各个变量的 liveness 分析，有一条语句是多余的，请问是哪一条？3’

```
                    // VS = {?}
t = 18
                    // VS = {?}
x = 17;
                    // VS = {?}
if(y >= 19){
                    // VS = {?}
    s = x * 2;
                    // VS = {s, z}
} else{
                    // VS = {?}
    t = y + 1;
                    // VS = {t, z}
}
```

5、有如下程序对外提供服务，此程序从 UDP 获得应用层输入(input 数组)和提供应用层输出（output 数组）。请简述如何最好地利用如下代码实现 DoS 攻击里的放大，放大倍数为多少？假定 UDP 头+IP 头+链路层协议头长度为 80byte， MTU 为 1500Byte。6'

```
char secret[2560] = ".....";  //2559 个可见字符加上/0
void Process(char* input, char* output){
   int x, i;
   sscanf(input, “%d”,&x);
   for(i=0;i<x && i<2560;i++)
       output[i] = secret[i];
}
```